

1. Storm-2077- China state threat actor, active since Jan 2024, targets financial institutions in US

Want to gather intelligence inc email data theft and sometimes used valid credentials harvested from successful compromise of system. Also gains access to eDiscovery applications.

Target emails containing sign-in credentials, confidential communication, financial records, business secrets, IP, and credentials for accessing systems.

Heavily relies on off the shelf malware-

Incident idea and sequence:

Key:

Successful activity associated with the incident
Unsuccessful activity associated with the incident
Red herring (alert not log)

Involved user identities:

User	Role
Louise Lonn	HR
Jane Payne	Sales user
Joe Vlogs	Marketing user

Historical alerts/ events:

Type	Details	How long ago?	Additional comments
Alert	Guest user invited to tenant	67 days	NB invited guest user to tenant- with domain C0gnizant
Event	Emails from Shrek593618@gmail.com sent to multiple users but blocked	90 days	Multiple users have emails from Shrek593618@gmail.com – subject 'Hello' but empty, then follow-up emails which are quarantined which contain a malicious payload
Event	Email sent to PC and NB from spoofed Graydon domain about installing Patagena	90 days	Email from spoofed Government body which resolves to Shrek593618@gmail.com and contains the malicious exe to set up C2
Event	Indicator removal on host- NB account deleting logs		
Alert	Turn off real time protection attempt	62 days	
ITSM ticket	Adding of 3 rd party screen capture tool to Company Portal	54 days	ITSM ticket where NB generated an incident requesting a screen recording tool- minimal security approval and added to Company Portal
Event	Users who have 3 rd party screen capture tool installed	54 days	
Events	Legitimate C2 traffic- EG: Updates in the background.		
Events	eDiscovery cases being requested by NB and PC for terms “payroll”, “salary”, “bonus”, “redundancy”, “disciplinary”, “performance review”, “acquisition”, “tribunal”, “confidential”, “secret” in emails		
Events	Archives created from the eDiscovery outputs and collected over weeks		
Alert	Add member to role group- HR Shared Mailbox added to eDiscovery Manager role in Purview		
Alert	Scheduled task creation- M365 OneDrive Maintenance	52 days	Alert where NB created a scheduled task- but this was the malicious actor not NB
Events	C2 traffic to same domain from NB over the last 44 days		

Additional information:

- NB & PCs accounts involved following an intelligence report that their credentials including session tokens were involved in a data breach recently. This report needs to be available to SOC- maybe on Sharepoint?

Known techniques	Actions	Inject	Additional info	Alert/ event	Status	Escalate?	Expected actions
Spear phishing	Phishing email sent	A malicious email is sent to multiple users and a shared mailbox "HR@creditsafe.com"		Event	Successful	No	N/A
	Malicious email removed from mailbox	The malicious email has been removed from a mailbox by Defender	The email has been removed from user mailboxes but not the HR@creditsafe.com	Alert	Unsuccessful	No	Investigate: Has the link been clicked on? Who is in the shared mailbox? Has the sender sent any emails to other people?
Phishing (T1566)	User has clicked on a malicious link	Jane Payne (sales) has clicked on a phishing email	This is a different phishing email which was delivered. SOC should identify that the access to the site was blocked by Netskope	Alert	Unsuccessful	No	Investigate: Was the link blocked? What is the phishing email? Has it now been removed from everyone?

Credential harvesting (T1056) Steal web session cookie (T1539)	User has clicked on a malicious link	Louise Lonn clicked on the phishing email from HR@creditsafe.com	The phishing page is an AiTM phishing page- fake M365 login page, LL enters credentials and authenticates	Alert	Successful	No	Password reset & sessions revoke
Valid Accounts (T1078)	Malicious actor signs into LLs account	Sign in to LLs account from UK location (using VPN) 2 minutes after the link was clicked	SignInLogs: LLs sign in logs need to be consistent and then a new sign in from Exchange Online (with no MFA required)	Event	Successful		MI?
	Phishing email forwarded to IT Help	Louise Lonn forwarded the phishing email to IT Help	LL says in the ticket she entered her password and MFA in the phishing email- needs to be a 20 min delay in this arriving to SOC so the malicious actor has already accessed LLs account	Alert	Successful	No	Ticket needs to be triaged by
Vulnerability exploit (T1190)	Attempts to exploit vulnerabilities on the VPN/Firewall	Networks inform SecOps that they've seen some strange behaviour on the Firewall earlier in the morning	Decide whether this is from SIEM logs (if we have them by then) or whether Networks tell us. IP address which this has come from should be behind the same VPN	Alert	Unsuccessful	Potential- Networks	

Commented [HR1]: Speak to Nath about having a mock up web page of ITSM tool as well as the SIEM

Commented [HR2]: We don't currently get logs in SIEM for this so how might we find out about this?

Commented [NG3R2]: Networks alert us?

Commented [NG4R2]: False positive? Scanned but nothing else, see if they listened to the Threat Hutnign Workshop

Commented [HR5R2]: Yes that's a really good shout- we'll have spear phishing as the actual RCA but there were also attempts to scan for vulnerabilities

Commented [HR6R2]: Maybe one of the outcomes of this could be we need more Networking logs into Sentinel

			provider as the sign-ins from LLs account				Are we vulnerable to that CVE?
Email forwarding (T1114)	Mailbox rule creation	RSS feed set up to forward emails from HR mailbox to guest C0gnizant user)		?	?	Yes- SOM	Investigate other mailbox rule
Email forwarding (T1114)	Mailbox rule creation	Create a mailbox rule to forward to an external party Shrek593618@gmail.com		Alert	Successful	Yes- SOH	Block the unknown recipient Search for any unusual mails to/ from that external party
	Searching sensitive terms	LL searching for emails which contain sensitive subjects	Searching for terms "payroll", "salary", "bonus", "redundancy", "disciplinary", "performance review", "acquisition", "tribunal", "confidential", "secret" in emails	Event	Successful	Yes	
	More than 50 files downloaded in an hour	Multiple emails downloaded with the above terms in them		Alert	Successful	Yes	Consider what other tools HR have access to where they may be able to pull

Commented [HR7]: Would we get an alert on this? Is this possible to do? cloud logs?

Commented [HR8]: Would we get events where these have been searched or would analysts have to determine from the contents of the ZIP or other logs?

							sensitive information
Archive collected data (T1114)	ZIP files created containing the downloaded emails	Multiple ZIPs created with names like 'HR_review_2026', 'payrollrecords2026' etc	Staging exfiltration- not sent anywhere yet	?	?		
	Same MFA is registered	Same phone number is observed on NBs and PCs accounts	This is a new phone number which has the Chinese sort code	Alert	Successful	Yes	
	eDiscovery tool sign in	Sign in events to Purview		Event	Successful		
Phishing (T1566)	User has clicked on a malicious link	Joe Vlogs (marketing) has clicked on a phishing email	This is a different phishing email and is unrelated to the ongoing incident. Not blocked by Netskope this time.	Alert	Successful	No	Password and session revocation Inform line manager Descope from current incident?
Exfiltration to Cloud Storage (T1567)	LL attempts to perform a sync between personal and business OneDrive	Attempt to sync OneDrive for Business to Personal		?	Unsuccessful		
	Same MFA registered on 2 devices	Goon registering his phone no on new starter	ITSM ticket which explains this behaviour		Successful		
Phishing	Email sent from "HR@creditsafe.com" mailbox to multiple users	Email contains exe for PayrollPortal.exe but this is actually Pantegana	Email is for a link to the New Payroll Portal for Sage. No alerting as threshold for alerting is not met	Event	Successful		
		Back and forth from users asking if it is legitimate		Event	Successful		
T1041 Exfiltration over C2	Suspicious HTTPS traffic	To the domain - aeifile.offiec.us.kg	Large volume of outbound data moved	Event	Successful		Who else has made connections

Commented [HR9]: We wouldn't actually get an alert on this at the moment- this should be available in some logs?

Commented [HR10]: I don't think we'd get an alert- but would we get events?

Commented [NG11R10]: I believe we would, let me do some digging

Commented [NG12R10]: Yeah, there are logs I can pull for this - we'd look in cloudapevents where the application is onedrive or m365 and the user agent contains a sync and then if the userid is a personal domain e.g. gmail, hotmail, msn etc

Commented [HR13R10]: This sounds good to me

							to this domain?
Scheduled task		Creation of scheduled tasks for persistence					
T1113 Screen capture		Install of screen capture tool from Company Portal		Event	Successful		See who else has this tool installed How did this tool come to be installed?
		Archives deleted		Event	Successful		
	New MFA registered to LLs account	New MFA has been registered to LLs account	This is a new phone number which has the Chinese sort code	Alert	Successful	Yes	
	Same MFA is registered	Same phone number is observed on NBs and PCs accounts	This is a new phone number which has the Chinese sort code	Alert	Successful	Yes	
	NB clicked on phishing email	User clicked on phishing link		Alert	Successful	?	
SparkRAT	New exe in user-writable location						

Commented [HR14]: NB account compromised before following a data breach - can we provide them with a mock Egress report for users whose credentials have been found on the dark web?

Commented [NG15R14]: Oh that would be cool, use exact format of the Saepio ones and add them as Lab Files

Commented [HR16R14]: That sounds good to me- we can come up with a list of users but if NB and PC are in a recent data breach which includes session tokens that should be an instant giveaway. We could also add someone who has since been a leaver to see if they record looking for them in the logs?

	Creation of scheduled task Creation of registry run key Suspicious service creation Unusual parent-child process relationships						
eDiscovery	LL sign in to Purview eDiscovery logs NB and PC been actioning eDiscovery cases for weeks- undiscovered LL actions a new eDiscovery						
Uses VPN services- ExpressVPN. WarpVPN							

Commented [HR17]: Will have different alerts for these- the exe needs to be obfuscated as a LOLBIN like OneDrive

Commented [NG18R17]: I like this could be something called "OneDriveSync.exe" in \AppData\Local\....

Parent: explorer.exe
Child: OneDriveSync.exe
Grandchild: PowerShell.exe?

Commented [NG19R17]: Then have the scheduled tasks and service creations all reference that .exe

Commented [HR20R17]: Yes that's really good! Hoping that SOC will be able to see the legitimate sync was blocked due to the controls and this is a LOLBIN not a legit process

Commented [HR21]: Want to bring NB and PC into scope for investigation now as should raise red flags that PC has been raising eDiscovery cases in Purview (not in job remit)

Commented [HR22R21]: My idea is then there are logs that suggest that PC and NB accounts have been compromised at some point but due to the CA policies they were not blocked- there was an alert/ event at an earlier point which was disregarded as normal behaviour because it was during the new phone roll out

Commented [NG23R21]: Okay, we can put old closed alerts in the simulator they can reference, that would be good and a potential learning point on how to handle blame "X closed this alert but it turned out to be important"

Commented [HR24R21]: Yeah this is fine- we'll make up a new SOC analyst who closed them off. Maybe one of the closures contains no notes so they understand the frustration of not being able to see why a decision has been made

Red herrings:

- Ransomware staging – lots of shadow-copy deletion attempts, recover settings changed, archive creation - testing the new backup provider backup and restore tooling
- Mass SharePoint downloads – getting ready for the confluence retirement
- High risk upload to cloud – would require follow up see how they handle prioritisation

Users affected:

- Nathan Browning
- Louise Lunn
- Phil Cottray

2. Oauth?

Expectations:
